

Advanced Security and Privacy

Dr. Kevin Theuermann

Kevin Theuermann

Ausbildung

2014 – 2016:

- FH Joanneum - eHealth Master of Science (M.Sc.)
- FH Campus02 - IT & Wirtschaftsinformatik (DI)

2018-2022:

- TU Graz – Doctoral School Informatics (Dr. techn.)

Arbeitserfahrung

2016-2022:

- TU Graz – Institut: IAIK, Wissenschaftlicher Mitarbeiter & Doktorand

2022-2024:

- TÜV Trust IT – Information Security Consultant

Seit Aug. 2024:

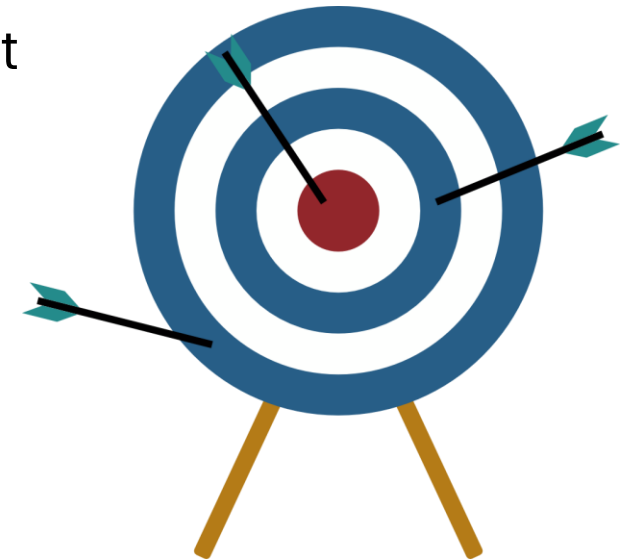
- GL Pharma – Chief Information Security officer



kevin.theuermann@gmail.com

Lernziele

- Erlernen grundlegender Methoden zum Schutz der IT-Sicherheit
- Kenntnisse über unterschiedliche Konzepte zum Schutz der Informationssicherheit
- Erlernen grundlegender Kenntnisse des Informationssicherheits-Risikomanagements und des Business Continuity Managements



Vorlesungen (VO)

23.10.2024	Einführung und Motivation	Informationssicherheit, Security Eigenschaften, Angriffsszenarien
	Verschlüsselungsmethoden	Symmetrische/Asymmetrische und hybride Verschlüsselung, Details zu Algorithmen
30.10.2024	HMAC/Digitale Signaturen Identitätsmanagement	Digitale & Elektronische Identitäten, Identitätsmodelle + Protokolle
06.11.2024	Informationssicherheitsmanagement	Relevante Standards, IS-Managementsysteme
13.11.2024	Informationssicherheits-Risikomanagement	Risikoidentifikation, -bewertung und -behandlung
20.11.2024	Business Continuity Management	Aufrechterhaltung der Betriebskontinuität kritischer Prozesse/Bereiche
27.11.2024	IT Security Konzepte (Blockchain)	Distributed Ledger Technologie, Konsensus- Protokolle, Anwendungsgebiete
04.12.2024	IT Security Konzepte (Grüner Pass)	EU Digital COVID Certificates, Green-Pass Architektur

Übungsteil (KU)

27.11.2024	1. Teil (08:30-11:00)	Aufgabenstellung, Gruppeneinteilung, Start der Übung
04.12.2024	2. Teil (08:30-11:00)	Weitere Bearbeitung der Aufgabenstellung
11.12.2024	3. Teil (08:30-11:00)	Weitere Bearbeitung der Aufgabenstellung
18.12.2024	4. Teil (08:30-11:00)	Weitere Bearbeitung der Aufgabenstellung, Vorbereitungen der Präsentationen
24.01.2025	5. Teil (08:30-13:00)	Präsentationen der Ergebnisse in Gruppen

- Gruppengröße: 4-5 Personen
- Bewertung der Abgabe + Präsentation
- Aufgabenstellung: Ausarbeitung eines Informationssicherheitskonzepts für ein fiktives Unternehmen (keine Programmierkenntnisse notwendig)

Beurteilung

- Schriftliche Prüfung
- Gesamtnote = Prüfungsergebnis (75%) + Übungsergebnis (25%)

Prüfung > 50% = 4

Note Prüfung: **3** + Note Übung: **2** = $3 \cdot 0.75 + 2 \cdot 0.25 = 2.75 \Rightarrow$ Note **3**

Note Prüfung: **3** + Note Übung: **1** = $3 \cdot 0.75 + 1 \cdot 0.25 = 2.5 \Rightarrow$ Note **2**

*(aufgerundet wird ab x.5**1**)*

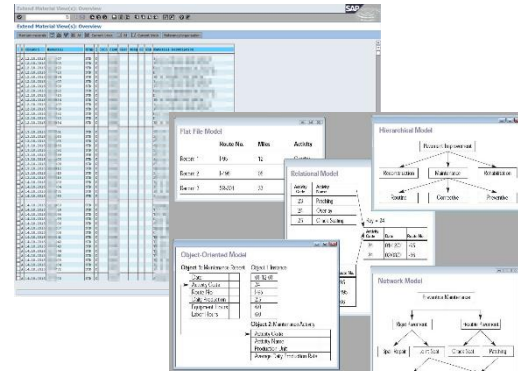


Was ist Informationssicherheit?

Informationssicherheit

Es gibt viele unterschiedliche Arten von Informationen (Beispiele)

elektronische Daten



Wissen



Dokumente in Papierform

Gesprochenes Wort



Informationssicherheitsschutzziele (Datensicherheit - CIA- Triade)

(C)onfidentiality
Vertraulichkeit

- Schutz von Informationen vor Offenlegung durch Unbefugte

Lesen/Verändern von Daten nur durch autorisierte Personen

(I)ntegrity
Integrität

- Schutz von Informationen vor Änderungen durch Unbefugte

Unveränderbarkeit und nachvollziehbare Änderungen

(A)vailability
Verfügbarkeit

- Gewährleistung, dass autorisierte Parteien bei Bedarf Zugriff auf Informationen erhalten

Ausfallssicherheit von Systemen

Möglichkeiten zum Schutz der Informationen

	Vertraulichkeit	Integrität	Verfügbarkeit
Wissen 	Vertraulichkeitsvereinbarungen	Wissensdatenbanken und Dokumentation	Wissenstransfer, Vertretungen
Gesprochenes Wort 	Verschlüsselung bei Verwendung elektr. Mitteln	Protokollierung und Überwachung von Änderungen	Aufzeichnung und sichere Ablage der Datei
Dokumente in Papierform 	Physische Zugriffskontrolle (Schlösser, Kameras, etc.)	Sichere Aufbewahrungsmethoden (verschlossene Schränke oder Tresore)	Physische Backups oder Duplikate
Elektronische Daten 	Verschlüsselung	Prüfsummen (z.B. Hash, Digitale Signaturen)	Redundanzsysteme

IT Sicherheit vs. Informationssicherheit



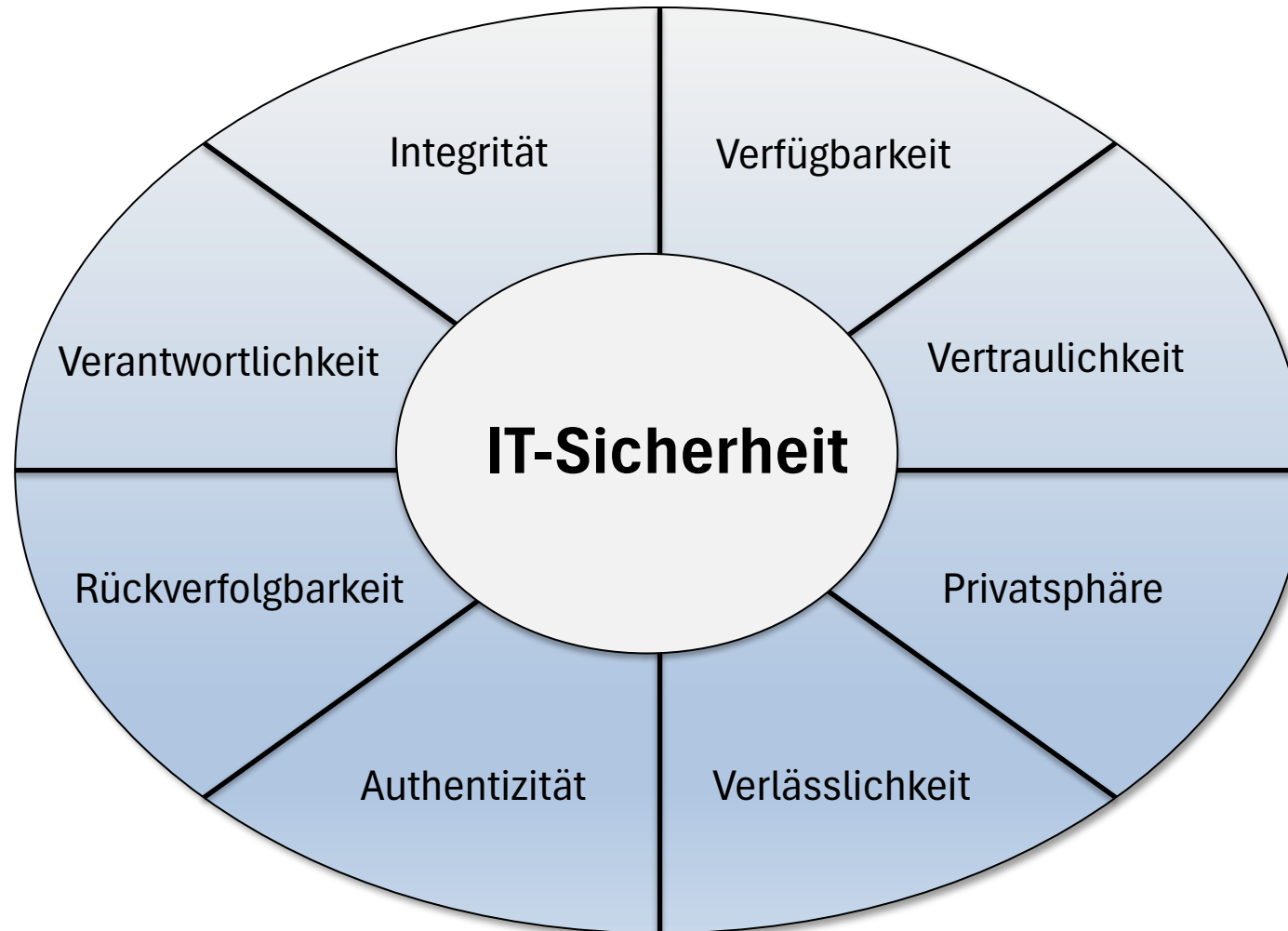
- Schutz von technischen Systemen vor Bedrohungen und Schäden
- Zugriffskontrollen, Kryptographie
- IT Sicherheit ist Teil der Informationssicherheit

- Schutz von Informationen
- Umfasst auch nicht-technische Systeme (Papierarchive, Betriebsgelände, etc.)
- Berücksichtigt betriebliche Strukturen (Kommunikationswege, Richtlinien, etc.)

Welche Sicherheitseigenschaften gibt es noch?



Security Eigenschaften



Security Eigenschaften

- **Authentizität (Authenticity):**
 - Echtheit und Vertrauenswürdigkeit einer Partei
- **Rückverfolgbarkeit (Non-repudiation):**
 - Erfolgte Tätigkeiten müssen nachweisbar und nicht-abstreitbar sein
- **Verantwortlichkeit (Accountability):**
 - Durchgeführte Handlungen müssen einem Akteur zurechenbar sein
- **Verlässlichkeit (Reliability):**
 - Die Fähigkeit eine Funktion ordnungsgemäß und fehlerfrei durchzuführen
- **Privatsphäre (Privacy):**
 - Schutz persönlicher und sensibler Daten



Security Eigenschaften

- Vertraulichkeit (Confidentiality): *Autorisierte Verwendung*
 - Vertraulichkeit bezieht sich darauf, wer auf bestimmte Informationen zugreifen darf
 - Daten dürfen nicht für die Öffentlichkeit oder nicht autorisierte Personen zugänglich sein
 - z.B.: Ärzte, Krankenschwestern und andere medizinische Fachkräfte, haben Zugriff auf Patientenakten
- Privatsphäre (Privacy): *Zweckgemäße Verwendung*
 - Die Privatsphäre von Daten bezieht sich darauf, wie diese Informationen verwendet werden, selbst wenn sie von autorisierten Personen eingesehen werden
 - In diesem Zusammenhang bedeutet Privatsphäre, dass Patientenakten nur für berufliche Zwecke genutzt bzw. eingesehen werden dürfen

Datenschutzgrundverordnung

- Ziel der DSGVO: Schutz der personenbezogenen und sensiblen Daten
- Gilt für alle Unternehmen, die Daten von EU-Bürgern verarbeiten, unabhängig vom Standort
- Grundsätze für die Verarbeitung personenbezogener Daten:
 - **Zweckbindung:** Daten dürfen nur für den festgelegten Zweck erhoben und verwendet werden.
 - **Datenminimierung:** Es sollen nur die für den Zweck notwendigen Daten erhoben werden.
 - **Speicherbegrenzung:** Daten dürfen nur so lange gespeichert werden, wie es für den Zweck notwendig ist.
 - **Integrität und Vertraulichkeit:** Angemessene Sicherheit der Daten muss gewährleistet sein.

Datenschutzgrundverordnung

- Artikel 25 Abs. 1: **Privacy by Design**
 - Datenschutz durch Technikgestaltung, d.h. von Anfang an
 - Geeignete technische/organisatorische Maßnahmen (z.B. Pseudonymisierung)
- Artikel 25 Abs. 2: **Privacy by Default**
 - Dient vor allem dem Schutz, weniger technikversierten Personen
 - Möglichkeit zur aktiven Anpassung der Privatsphäre (z.B. Add-Blocker im Browser)

Angriffsmodell auf Datensicherheit: Kommunikation



Nachricht lesen

- **Angriff:** Eve (Angreiferin) hat Zugriff auf die Nachricht (Abfangen) und liest sie (Vertraulichkeitsverletzung).
- **Auswirkung:** Vertraulichkeit
- **Typische Sicherheitsfunktion:**
Verschlüsselung

Indirektes Ableiten von Informationen

- **Angriff:** Eve (Angreifer) hat Zugriff auf die geschützte Nachricht (Abfangen) und extrahiert indirekt Informationen. Eve weiß beispielsweise, dass ein positives COVID-19-Testergebnis aufgrund zusätzlicher Informationen im Vergleich zu einem negativen Ergebnis zu einer großen Nachrichtengröße führt. In diesem Fall würde Eve den Inhalt der Nachricht selbst dann erkennen, wenn sie verschlüsselt ist, indem sie nur ihre Größe betrachtet.

100KB

Positiv



Negativ

80KB

- **Auswirkung:** Vertraulichkeit
- **Typische Sicherheitsfunktion:**

Verschlüsselung und der Versuch, zusätzliche Informationen einzuschränken (z. B. die Größe jeder Nachricht gleich zu machen oder Nachrichten „glätten“).

Kommunikation aufzeichnen und entschlüsseln

- **Angriff:** Eve (Angreiferin) hat die gesamte Kommunikation zwischen Alice und Bob aufgezeichnet und kann zum Zeitpunkt der Aufzeichnung keine Informationen extrahieren (aufgrund der geschützten Nachrichten). Eve wartet jedoch auf den richtigen Moment und stiehlt den Verschlüsselungsschlüssel von Bobs Gerät. Eve kann jetzt die gesamte aufgezeichnete Kommunikation entschlüsseln.
- **Auswirkung:** Vertraulichkeit, evtl. Integrität
- **Typische Sicherheitsfunktion:**
Verschlüsselung mit Perfect-Forward-Secrecy (PFS)

Replay-Angriff

- **Angriff:** Eve (Angreifer) zeichnet vorherige Nachrichten auf und schickt sie zu einem späteren Zeitpunkt erneut an einen Empfänger.
- **Auswirkung:** Integrität (Authentizität)
- **Typische Sicherheitsfunktion:** abhängig vom Protokoll, allgemeiner Replay-Schutz: Sicherstellen, dass die Nachricht aktuell ist über Zeitstempel oder Protokolle.



Verändern der unverschlüsselten Nachricht

- **Angriff:** Eve (Angreiferin) fängt eine unverschlüsselte Nachricht ab und modifiziert sie nach ihren Bedürfnissen.
- **Auswirkung:** Integrität (Authentizität)
- **Typische Sicherheitsfunktion:** HMACS, Signaturen, die sicherstellen, dass Nachrichtenänderungen vom Empfänger erkannt werden.

Verändern der verschlüsselten Nachricht

- **Angriff:** Eve (Angreiferin) fängt geschützte (verschlüsselte) Nachrichten ab und modifiziert sie nach ihren Bedürfnissen.
- **Auswirkung:** Integrität
- **Typische Sicherheitsfunktion:** Verschlüsselung allein schützt die Nachricht nicht vor Veränderung, zusätzlich HMAC oder digitale Signatur notwendig

Impersonisieren

- **Angriff:** Eve (Angreiferin) injiziert/verändert Nachrichten so, dass sie von Bob/Alice (Identitätswechsel) zu stammen scheinen.
- **Auswirkung:** Integrität (Authentizität)
- **Typische Sicherheitsfunktion:** HMACs, Signaturen



Nachricht unterdrücken

- **Angriff:** Eva unterdrückt einige/alle Nachrichten. (z.B: Denial-of-Service-Attack)
- **Auswirkung:** Verfügbarkeit;
Beispiel – selbstfahrendes Auto: Alice ist ein Bremspedal und Bob ist die Bremse -> Unterdrücken der Information „Jetzt bremsen“ führt dazu, dass die Bremse nicht funktioniert
- **Typische Sicherheitsfunktion:** Vollständig protokollabhängig, in vielen Fällen schwer abzuschwächen.

Welche Schutzmaßnahmen gibt es dagegen?

Angriffe	Beschreibung
Nachricht lesen	Ein Angreifer liest den Inhalt einer Nachricht.
Indirektes Ableiten von Informationen	Ein Angreifer kann Meta-Informationen von der Kommunikation ableiten (Kommunikationsmuster etc.).
Kommunikation aufzeichnen und mit (gestohlenen) Schlüssel entschlüsseln	Ein Angreifer kann eine Kommunikation aufzeichnen und diese mit einem (gestohlenen) Schlüssel entschlüsseln.
Replay-Angriff	Ein Angreifer versendet eine aufgezeichnete Nachricht erneut.
Verändern der unverschlüsselten Nachricht	Ein Angreifer modifiziert den Plain-Text einer Nachricht.
Verändern der verschlüsselten Nachricht	Ein Angreifer modifiziert den Ciphertext einer Nachricht.
Impersonalisieren	Ein Angreifer gibt sich als einen bestimmten Versender einer Nachricht aus.
Nachricht unterdrücken	Ein Angreifer verhindert die Zustellung einer Nachricht.

Advanced Security and Privacy

Dr. Kevin Theuermann